

Чек-лист аудита безопасности автоматизированных систем

Базовый чек-лист для первичной оценки защищённости
Составлен на основе требований ФСТЭК России

* Каждый пункт — это вопрос. Если ответ «Нет» — значит, есть риск. Галочка в окне «☐» = проверено, всё в порядке.*

Раздел 1. Управление доступом
☐ Включена двухфакторная аутентификация для критичных сервисов (VPN, почта, админ-панели)
☐ У сотрудников нет прав локального администратора по умолчанию
☐ Учётная запись блокируется после нескольких неудачных попыток входа
☐ Учётные записи уволенных сотрудников удаляются в течение суток
☐ Пароли по умолчанию изменены на всём оборудовании (роутеры, камеры, коммутаторы)

Раздел 2. Сетевая безопасность

☐ Гостевая сеть Wi-Fi изолирована от рабочей
☐ Неиспользуемые порты закрыты на межсетевом экране
☐ Для удалённого доступа используется VPN с надёжным шифрованием
☐ Удалённый доступ (RDP, SSH, Telnet) снаружи отключён, если не используется

Раздел 3. Защита данных и резервное копирование
☐ Резервное копирование критичных данных выполняется регулярно
☐ Восстановление из резервной копии проверялось на практике
☐ Хотя бы одна копия резервной копии хранится офлайн
☐ Шифрование включено на ноутбуках и базах с персональными данными

Раздел 4. Обновления и уязвимости
☐ Обновления безопасности операционной системы установлены на всех компьютерах
☐ Используется только лицензионное или проверенное программное обеспечение
☐ Антивирусные базы обновляются автоматически

Раздел 5. Мониторинг
☐ Включено журналирование входов в систему и действий администраторов
☐ Настроены оповещения о подозрительных событиях (например, множественные неудачные входы)
☐ Назначен ответственный за реагирование на инциденты

Раздел 6. Физическая безопасность
☐ Серверное и сетевое оборудование размещено в защищённом помещении с ограниченным доступом
☐ Для посетителей предусмотрена регистрация и сопровождение
☐ Резервные источники питания (ИБП) обеспечивают корректное завершение работы при сбое электросети

Раздел 7. Реагирование и восстановление после инцидентов
☐ Сотрудники знают, кому сообщать об инциденте или подозрении на него
☐ Определены сроки и порядок действий при потере конфиденциальных данных
☐ Проводится периодический анализ инцидентов и мероприятий по устранению причин
☐ Утверждён план восстановления работы после серьёзного сбоя или атаки